

REST API Contracts — SIMPATIK Posyandu Tulip

Catatan

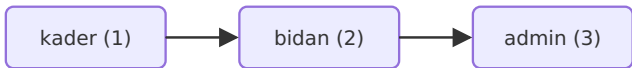
Dokumentasi ini di-extract langsung dari *source code* di `server/src/http/`. Semua endpoint sudah diverifikasi dari controller dan `server.ts`.

Ringkasan Arsitektur

Komponen	Detail
Framework	Express 5 (Node.js ≥ 24)
Database	PostgreSQL via Supabase (hanya sebagai managed PG, bukan API publik)
Port bawaan	4321 (konfigurasi via <code>PORT</code> di <code>.env</code>)
Alamat bawaan	127.0.0.1 (konfigurasi via <code>HOST</code> di <code>.env</code>)
Body parser	JSON, limit 4 MB
Autentikasi	Cookie <code>sesi</code> (httpOnly, SameSite=Lax) untuk Portal web; Bearer token untuk tablet/Android
Sesi	Disimpan di database (token 256-bit acak, hanya SHA-256 digest yang disimpan), umur 12 jam
CSRF	Wajib <code>Content-Type: application/json</code> untuk semua metode non-GET/HEAD/OPTIONS
Rate limiting	Maks 5 gagal login per (<code>username</code> , <code>IP</code>), jeda 15 menit
CORS	Hanya <code>/api/v1/*</code> — origin <code>null</code> (untuk WebView tablet Android)

Peran & Izin (Hirarki Berjenjang)

Peran lebih tinggi mewarisi seluruh hak peran di bawahnya.



Aksi	Peran Minimum
lihat-dashboard	kader
lihat-anak	kader
lihat-kms	kader
lihat-rekap	kader
daftar-anak-lapangan	kader
catat-pengukuran-lapangan	kader

selesaikan-sesi-lapangan	kader
ubah-anak	bidan
ubah-pengukuran	bidan
gabung-duplikasi	bidan
selesaikan-konflik-impor	bidan
unduh-rekap	bidan
kelola-wilayah-rt	admin
kelola-periode	admin
hapus-data	admin
kelola-akun	admin
jalankan-impor	admin

Daftar Lengkap Endpoint

1. Autentikasi — Portal Web (Cookie)

Rute di-mount di `/api` (tanpa `/v1`).

#	Metode	Endpoint	Auth	Deskripsi
1	POST	<code>/api/masuk</code>	Publik	Login Portal web. Set cookie <code>sesi</code> httpOnly.
2	POST	<code>/api/keluar</code>	Cookie sesi	Logout Portal web. Hapus cookie <code>sesi</code> .
3	GET	<code>/api/saya</code>	Cookie / Bearer	Profil pengguna yang sedang login (nama, username, peran, RT).

POST `/api/masuk`

```
// Request
{
  "username": "string (wajib, di-trim)",
  "kataSandi": "string (wajib)"
}

// Response 200
{
  "pengguna": { "id": 1, "peran": "kader", "rt": "001", "aktif": true }
}
// + Set-Cookie: sesi=<token>; HttpOnly; SameSite=Lax; Path=/; Max-Age=43200

// Response 400
{ "galat": "Nama pengguna dan kata sandi wajib diisi" }

// Response 401
{ "galat": "..." }

// Response 429 (rate limited)
// Header: Retry-After: <detik>
{ "galat": "Terlalu banyak percobaan. Coba lagi dalam N detik." }
```

POST /api/keluar

```
// Response 204 (No Content) – selalu berhasil
```

GET /api/saya

```
// Response 200
{
  "pengguna": {
    "id": 1,
    "peran": "kader",
    "rt": "001",
    "aktif": true,
    "nama": "Siti Aminah",
    "username": "siti.aminah"
  }
}

// Response 401
{ "galat": "Sesi tidak berlaku" }
```

2. Autentikasi — Tablet/Android (Bearer Token)

Rute di-mount di `/api/v1`.

#	Metode	Endpoint	Auth	Deskripsi
4	POST	/api/v1/masuk	Publik	Login tablet. Mengembalikan Bearer token.
5	POST	/api/v1/keluar	Bearer token	Logout tablet. Mencabut token.

POST /api/v1/masuk

```
// Request
{
  "username": "string (wajib, di-trim)",
  "kataSandi": "string (wajib)"
}

// Response 200
{
  "token": "base64url-string",
  "kedaluwarsa": "2026-10-05T07:37:00.000Z",
  "pengguna": { "id": 1, "peran": "kader", "rt": "001", "aktif": true }
}

// Response 400 / 401 / 429 – sama seperti POST /api/masuk
```

POST /api/v1/keluar

```
// Header: Authorization: Bearer <token>
// Response 204 (No Content)
```

3. Health Check

#	Metode	Endpoint	Auth	Deskripsi
6	GET	/api/v1/kesehatan	Publik	Cek koneksi database. Untuk pre-flight Android.

GET /api/v1/kesehatan

```
// Response 200
{
  "status": "siap",
  "database": "terhubung",
  "waktuServer": "2026-10-04T12:37:00.000Z"
}

// Response 500 (jika database tidak terhubung)
{ "galat": "Terjadi kesalahan di server" }
```

4. Data Anak

Rute di-mount di `/api/v1`. Semua memerlukan autentikasi + izin. Data dibatasi per RT untuk peran kader.

#	Metode	Endpoint	Izin Minimum	Deskripsi
7	GET	/api/v1/anak	lihat-anak	Daftar anak berpaginasi + pencarian
8	GET	/api/v1/anak/:id	lihat-anak	Profil lengkap seorang anak
9	GET	/api/v1/anak/:id/pengukuran	lihat-kms	Riwayat pengukuran untuk KMS
10	POST	/api/v1/anak	daftar-anak-lapangan	Upsert pendaftaran anak (berdasarkan NIK)
11	POST	/api/v1/pengukuran	catat-pengukuran-lapangan	Upsert pengukuran + hitung gizi server-side

GET /api/v1/anak

Query params:

- ?cari=<string> – kata kunci pencarian (opsional)
- &halaman=<number> – nomor halaman, default 1
- &ukuran=<number> – item per halaman, default 25

```
// Response 200
{
  "items": [...],
  "total": 150,
  "halaman": 1,
  "ukuran": 25
}
```

GET /api/v1/anak/:id

```
// Response 200
{ "anak": { ... } }

// Response 404
{ "galat": "Anak tidak ditemukan." }
```

GET /api/v1/anak/:id/pengukuran

```
// Response 200
{ "pengukuran": [...] }

// Response 404
{ "galat": "Anak tidak ditemukan." }
```

POST /api/v1/anak

```
// Request – body sesuai skema pendaftaran anak
{ ... }

// Response 201
{ "anak": { ... } }
```

POST /api/v1/pengukuran

```
// Request – body sesuai skema pengukuran
{ ... }

// Response 201
{ "pengukuran": { ... } }
```

5. Sinkronisasi Offline (Tablet)

#	Metode	Endpoint	Izin Minimum	Deskripsi
12	GET	/api/v1/sinkronisasi	lihat-anak	Paket sasaran + pengukuran untuk cache offline

```
// Response 200
{ ... } // Seluruh data sasaran dan pengukuran untuk RT pengguna
```

6. Dashboard / Beranda

#	Metode	Endpoint	Izin Minimum	Deskripsi
13	GET	/api/v1/periode	lihat-dashboard	Daftar periode yang tersedia
14	GET	/api/v1/beranda	lihat-dashboard	Data beranda per periode

GET /api/v1/periode

```
// Response 200
{ ... } // Daftar periode
```

GET /api/v1/beranda

Query params:
?periode=YYYY-MM – wajib, format YYYY-MM

```
// Response 200
{ ... } // Data statistik beranda

// Response 400
{ "galat": "Periode harus berformat YYYY-MM." }

// Response 404
{ "galat": "Periode tidak tersedia." }
```

7. Kelola Pengguna (Admin Only)

Rute di-mount di `/api` (tanpa `/v1`).

#	Metode	Endpoint	Izin Minimum	Deskripsi
15	GET	<code>/api/pengguna</code>	<code>kelola-akun</code>	Daftar semua akun + pilihan RT
16	POST	<code>/api/pengguna</code>	<code>kelola-akun</code>	Buat akun baru
17	PATCH	<code>/api/pengguna/:id</code>	<code>kelola-akun</code>	Ubah akun (kata sandi kosong = tetap)

Penting

Tidak ada `DELETE` — akun **dinonaktifkan**, bukan dihapus, agar jejak audit tetap utuh.

GET `/api/pengguna`

```
// Response 200
{ ... } // Daftar akun dan pilihan RT binaan
```

POST `/api/pengguna`

```
// Request
{ ... } // Data akun baru, termasuk kata sandi awal

// Response 201
{ "pengguna": { ... } }
```

PATCH `/api/pengguna/:id`

```
// Request
{ ... } // Field yang diubah; kata sandi kosong = tidak diubah

// Response 200
{ "pengguna": { ... } }

// Response 404
{ "galat": "Pengguna tidak ditemukan." }
```

8. Sasaran & Impor Excel

Rute di-mount di `/api/v1`.

#	Metode	Endpoint	Izin Minimum	Deskripsi
18	GET	<code>/api/v1/sasaran</code>	<code>lihat-anak</code>	Daftar sasaran (opsional filter periode)
19	POST	<code>/api/v1/sasaran/pratinjau</code>	<code>jalankan-impor</code>	Pratinjau hasil impor Excel (validasi)
20	POST	<code>/api/v1/sasaran/impor</code>	<code>jalankan-impor</code>	Eksekusi impor Excel ke database
21	POST	<code>/api/v1/sasaran/tutup-sesi</code>	<code>selesaikan-sesi-lapangan</code>	Tutup sesi lapangan

GET `/api/v1/sasaran`

Query params:
`?periode=<string>` – filter periode (opsional)

```
// Response 200
{ ... } // Daftar sasaran
```

POST `/api/v1/sasaran/pratinjau`

```
// Request – body berisi data Excel (base64)
{ ... }
```

```
// Response 200
{ ... } // Hasil validasi pratinjau
```

POST `/api/v1/sasaran/impor`

```
// Request
{ ... }
```

```
// Response 201
{ "hasil": { ... } }
```

POST `/api/v1/sasaran/tutup-sesi`

```
// Request
{ ... }
```

```
// Response 200
{ "hasil": { ... } }
```

9. Catch-All

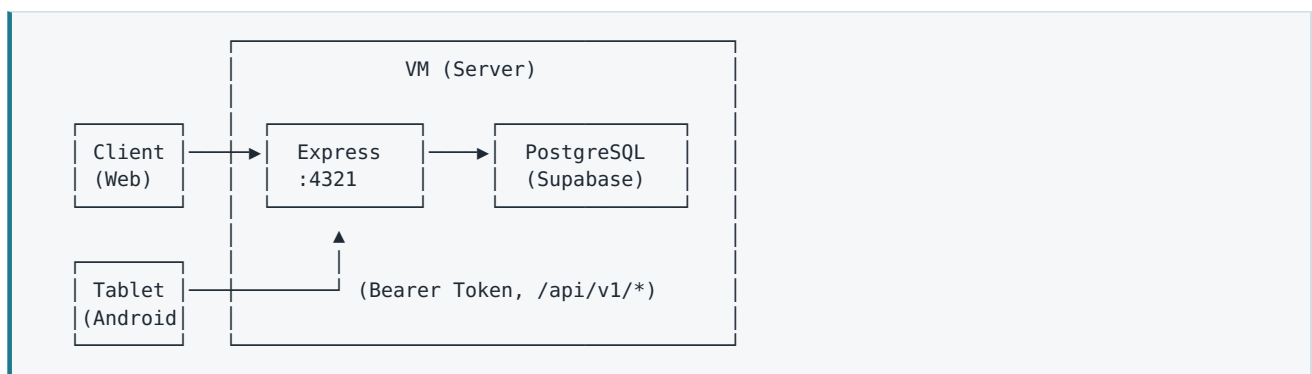
#	Metode	Endpoint	Deskripsi
—	*	<code>/api/*</code> (tidak cocok)	Mengembalikan 404

```
// Response 404
{ "galat": "Rute tidak ada" }
```

Envelope & Galat Global

Pola	Contoh
Sukses daftar	<code>{ items, total, halaman, ukuran }</code>
Sukses detail	<code>{ anak: {...} }</code> atau <code>{ pengguna: {...} }</code>
Galat	<code>{ "galat": "Pesan kesalahan" }</code>
Galat server	<code>{ "galat": "Terjadi kesalahan di server" } (500)</code>

Ringkasan untuk Arsitektur VM Live



Port & Variabel Lingkungan yang Perlu Diatur

Variabel	Contoh	Keterangan
<code>PORT</code>	<code>4321</code>	Port HTTP server
<code>HOST</code>	<code>0.0.0.0</code>	Bind address (set <code>0.0.0.0</code> untuk akses dari luar)
<code>NODE_ENV</code>	<code>production</code>	Aktifkan cookie <code>Secure</code>
<code>DATABASE_URL</code>	<code>postgresql://...</code>	Connection string Supabase/PostgreSQL

Endpoint yang Harus Terbuka dari Luar

Path	Protokol	Catatan
<code>/api/*</code>	HTTPS (di balik reverse proxy)	Semua REST API
Port <code>4321</code>	TCP	Di-reverse-proxy ke <code>:443</code> HTTPS

Total: 21 endpoint aktif (+ 1 catch-all 404)